

Checklist de seguridad básica

Bayona Valdez, Fany · Desarrollo de Sistemas Inteligentes II · 2025-2 · Instituto Superior Privado Khipu · 20/09/2026

Entregable N.º 3 de las bases del proyecto final. Estado de cada práctica de seguridad básica exigida: validación de inputs, manejo de errores, credenciales fuera del código fuente y control de acceso. La columna de verificación indica la prueba automatizada (pytest) o el archivo que la respalda.

Validación de inputs

Práctica	Implementación	Verificación	Cumple
Esquemas estrictos	Pydantic en todos los endpoints de escritura (app/schemas.py)	F14/F15: 422	Si
Dominios cerrados	tipo/canal/etapa/estado restringidos por regex	tests API	Si
Longitudes y rangos	max_length en textos; montos ≥ 0 ; horas ≤ 1 año	tests API	Si
Correo válido	EmailStr con email-validator	F15: 422	Si
Paginación acotada	límite ≤ 200 por consulta	Query(le=200)	Si

Manejo de errores

Práctica	Implementación	Verificación	Cumple
Sin stack traces	FastAPI devuelve JSON {detail} controlado	revisión API	Si
Login genérico	"Credenciales incorrectas" (no revela el campo fallido)	F02/F03: 401	Si
404 limpios	recursos inexistentes sin datos internos	F13: 404	Si
Frontend estable	try/catch + notificación en cada llamada	revisión UI	Si

Credenciales y secretos

Práctica	Implementación	Verificación	Cumple
Sin secretos en código	SECRET_KEY/DATABASE_URL por variables de entorno	app/config.py	Si
Plantilla sin secretos	.env.example documentado	repositorio	Si
.env ignorado	excluido del control de versiones	.gitignore	Si

Práctica	Implementación	Verificación	Cumple
Hash de contraseñas	PBKDF2-HMAC-SHA256, 120 000 iteraciones + salt	app/auth.py	Sí
Timing-safe	comparación con hmac.compare_digest	app/auth.py	Sí
Tokens con expiración	JWT HS256, 8 h configurable	RNF01	Sí

Control de acceso (RNF01)

Práctica	Implementación	Verificación	Cumple
API protegida	todas las rutas exigen token (salvo login y health)	F05: 401	Sí
Jerarquía de roles	lector < admisión < gestor < admin	F07/F08	Sí
Escritura restringida	crear/editar exige rol admisión o superior	F07: 403	Sí
Borrado solo admin	eliminación de contactos exclusiva del administrador	F16: 403/204	Sí

Frontend

Práctica	Implementación	Verificación	Cumple
Token en cliente	localStorage con logout que lo elimina	static/js/api.js	Sí
Expiración manejada	respuesta 401 redirige al login	interceptor api.js	Sí
Protección XSS	todo contenido dinámico se escapa	views.js esc()	Sí

Pendientes para producción real (fuera del alcance académico)

- HTTPS terminado por la plataforma (Render/Docker).
- Rate limiting en /auth/login (p. ej. slowapi) si el sistema se expone de forma permanente.
- Rotación programada de SECRET_KEY y cifrado en reposo del disco gestionado de la base de datos.